

Manual 21 — Implementación controlada de seguridad OT / ICS

Localización controlada es-419 — desarrollo

****Orden de serie:**** 21

****Fuente inglesa vinculante:**** blob `e0a7095d14ce988e988077327ba1f01a8ffbde88`

****Línea base pública principal:**** NIST SP 800-82 Rev. 3

****Límites de referencia:**** serie ISA/IEC 62443; avisos y mitigaciones ICS/OT de CISA

****Límite de control:**** Traducción no oficial del proyecto. Esta guía no reproduce texto protegido de normas, no establece certificación, no sustituye la ingeniería de seguridad funcional y no convierte avisos en requisitos obligatorios.

1. Propósito, alcance y límites de fuentes

Definir los entornos OT/ICS, instalaciones, procesos, sistemas, redes, aplicaciones, dispositivos de campo, servicios de soporte e interfaces incluidos. Registrar versiones de fuentes y distinguir guía pública, normas protegidas, documentación de proveedores y avisos de vigencia temporal. Evidencia: alcance aprobado, registro de fuentes, exclusiones, mapa de instalaciones/sistemas y vigilancia de cambios.

2. Misión OT, seguridad funcional y contexto del proceso

Las decisiones de ciberseguridad deben preservar la operación segura y confiable del proceso físico. Documentar funciones críticas, dependencias de seguridad, restricciones ambientales, disponibilidad, interrupción tolerable y situaciones que requieren revisión de ingeniería o seguridad funcional. Evidencia: criticidad del proceso, interfaces de riesgos, restricciones operativas y decisiones aprobadas.

3. Gobierno, roles y responsabilidad

Establecer responsabilidad entre dirección, liderazgo de planta, ingeniería de control, operaciones, seguridad funcional, ciberseguridad, TI, seguridad física, proveedores y respuesta a incidentes. Definir autoridad para aceptar riesgo, acceso remoto, cambios, interrupciones y acciones de emergencia. Evidencia: estatuto, RACI, escalamiento, suplencias, reuniones y decisiones.

4. Zonas, conductos y segmentación de arquitectura

Modelar zonas de confianza, niveles de seguridad o agrupaciones equivalentes, conductos, dispositivos de frontera, centros de control, sistemas de seguridad, supervisión, estaciones de ingeniería, redes de campo e interfaces empresariales. Limitar comunicaciones innecesarias sin afectar flujos requeridos. Evidencia: diagramas, matrices de flujo, reglas de frontera, excepciones y pruebas.

5. Inventario y propiedad de activos OT

Mantener inventarios autorizados de PLC, DCS, HMI, historiadores, estaciones de ingeniería, componentes de seguridad, gateways, redes, servidores, activos virtuales,

inalámbricos, sensores, actuadores, aplicaciones y firmware. Registrar propietario, ubicación, función, criticidad, versión, identidad de red, soporte y ciclo de vida. Reconciliar descubrimiento pasivo, registros de ingeniería y mantenimiento.

6. Clasificación de sistemas y componentes

Clasificar según criticidad del proceso, consecuencia de seguridad, dependencia operativa, exposición, recuperabilidad e impacto de ciberseguridad. No reducir consecuencias físicas o pérdida de control a una sola puntuación de negocio. Evidencia: criterios, clasificaciones, justificación, dependencias y disparadores de reevaluación.

7. Evaluación de riesgos de ciberseguridad OT

Evaluar escenarios creíbles considerando arquitectura, exposición, debilidades conocidas, capacidad del adversario, consecuencias del proceso, seguridad, ambiente, dificultad de recuperación y salvaguardas existentes. Incluir dependencias con TI, nube, proveedores remotos y telecomunicaciones. Evidencia: escenarios, supuestos, salvaguardas, riesgo residual, propietarios y tratamientos.

8. Configuración segura y endurecimiento

Definir líneas base adecuadas a cada tecnología OT y sus restricciones operativas. Deshabilitar servicios innecesarios cuando sea seguro, proteger administración, gestionar credenciales predeterminadas, interfaces removibles y fuentes de tiempo, y documentar desviaciones operativas. Evidencia: líneas base, exportaciones, verificaciones, desviaciones y remediación.

9. Identidad, autenticación y control de acceso

Aplicar mínimo privilegio y responsabilidad individual cuando sea técnicamente viable, considerando limitaciones heredadas y necesidades de emergencia. Separar privilegios de operador, ingeniero, administrador, servicio, proveedor y aplicación. Proteger credenciales privilegiadas y documentar controles compensatorios cuando un dispositivo no soporte autenticación fuerte.

10. Acceso remoto y mantenimiento privilegiado

Permitir conectividad remota solo mediante rutas aprobadas, monitoreadas y limitadas en tiempo. Exigir autorización explícita, intermediación segura, autenticación fuerte donde sea posible, evidencia de sesión y revocación rápida. El acceso de emergencia debe controlarse y revisarse posteriormente. Evidencia: arquitectura, registros, sesiones, aprobaciones y pruebas de terminación.

11. Segmentación de red y protección de fronteras

Controlar tráfico entre TI empresarial, redes OT, zonas de control, sistemas relacionados con seguridad, redes inalámbricas, proveedores y servicios externos. Usar comunicaciones permitidas explícitamente cuando sea viable y validar reglas contra flujos documentados. Evidencia: firewalls/ACL, líneas base de flujo, revisiones, pruebas y excepciones.

12. Protocolos industriales y seguridad de comunicaciones

Inventariar protocolos industriales y de soporte, sus supuestos de confianza, capacidades de autenticación/cifrado, exposición y dependencias operativas. Aplicar variantes seguras, gateways, filtrado, controles de integridad o segmentación compensatoria donde las capacidades nativas sean limitadas. Todo cambio debe contar con validación de ingeniería.

13. Arquitectura defensiva y salvaguardas en capas

Diseñar defensa en profundidad sobre acceso físico, fronteras de red, hosts, aplicaciones, identidades, ingeniería, monitoreo, respaldos, recuperación y procedimientos. No depender de un único firewall, producto de endpoint o supuesto de aislamiento. Evidencia: arquitectura por capas, dependencias, modos de falla y validación.

14. Monitoreo, registros y detección de anomalías

Recolectar telemetría de seguridad y operación proporcional al riesgo sin desestabilizar procesos. Priorizar fronteras, autenticación, estaciones de ingeniería, servidores, acceso remoto, cambios críticos y monitoreo pasivo OT. Definir sincronización de tiempo, retención, triaje y escalamiento. Evidencia: cobertura, salud de fuentes, detecciones e investigaciones.

15. Gestión de vulnerabilidades y exposición

Identificar vulnerabilidades, configuraciones inseguras, servicios expuestos, componentes sin soporte y avisos relevantes. Evaluar explotabilidad junto con consecuencia del proceso, exposición, guía del proveedor, salvaguardas y ventanas de mantenimiento. No equiparar una puntuación de severidad con el riesgo OT. Evidencia: hallazgos, correlación, decisiones, mitigaciones y repuebas.

16. Gestión de parches y actualizaciones

Evaluar firmware, sistemas operativos, aplicaciones y actualizaciones mediante información del proveedor, compatibilidad de ingeniería, pruebas cuando sean viables, reversión, ventanas de mantenimiento e impacto en proceso/seguridad. Evitar cambios no probados en producción crítica. Evidencia: inventarios, aplicabilidad, pruebas, aprobaciones, despliegues y riesgo diferido.

17. Control de configuración y cambios

Gestionar cambios de hardware, software, lógica, red, firmware, cuentas, reglas y arquitectura mediante evaluación y aprobación. Definir cambios de emergencia y revisión posterior. Verificar respaldos y recuperación antes de cambios materiales y monitorear deriva no autorizada. Evidencia: tickets, revisión de ingeniería, pruebas, aprobaciones y configuraciones antes/después.

18. Respaldos, restauración e ingeniería de recuperación

Proteger copias recuperables de lógica de control, configuraciones, recetas, historiadores, imágenes, documentación, licencias, claves y demás material requerido. Mantener copias aisladas o protegidas cuando corresponda y probar restauración de forma realista. Evidencia: inventarios, configuraciones, pruebas, dependencias y remediación.

19. Respuesta a incidentes OT

Mantener procedimientos OT para detección, triaje, contención, erradicación, recuperación, preservación de evidencia, comunicaciones y escalamiento, integrados con seguridad y operaciones. La contención que pueda cambiar el proceso físico exige juicio operativo autorizado. Evidencia: planes, contactos, incidentes, ejercicios, decisiones y lecciones aprendidas.

20. Continuidad, modos degradados y operación manual

Definir cómo mantener procesos críticos de forma segura durante interrupción cibernética, pérdida de conectividad, supervisión, proveedores o servicios de ingeniería. Documentar modos degradados y operación manual solo cuando sean operacionalmente válidos y entrenados. Evidencia: planes, dependencias, procedimientos, ejercicios, prioridades de recuperación y acciones correctivas.

21. Seguridad de proveedores y terceros OT

Inventariar OEM, integradores, mantenimiento, servicios administrados, nube, telecomunicaciones y proveedores de software/componentes. Definir requisitos para acceso remoto, credenciales, actualizaciones, notificación de incidentes, soporte, subcontratistas, evidencia y terminación. Evidencia: contratos, evaluaciones, accesos, avisos, procedencia y remediación.

22. Ingeniería segura y ciclo de vida del sistema

Integrar requisitos de ciberseguridad desde diseño y adquisición hasta puesta en servicio, operación, modificación, mantenimiento y retiro. Definir revisiones de diseño, criterios de aceptación, documentación, pruebas de aceptación apropiadas, expectativas de soporte y retiro seguro. Evidencia: requisitos, revisiones, aceptación, planes de ciclo de vida y retiro.

23. Protección física y ambiental

Coordinar ciberseguridad con acceso a instalaciones, gabinetes, salas de control, ubicaciones de campo, puertos, energía, enfriamiento, controles ambientales y manipulación. Aplicar protecciones según consecuencia y condiciones reales. Evidencia: accesos, inspecciones, monitoreo ambiental, controles físicos, visitas y acciones correctivas.

24. Medios removibles y dispositivos portátiles

Controlar laptops, estaciones portátiles, almacenamiento removible, diagnóstico y medios de proveedores antes de conectarlos a OT. Definir autorización, análisis o transferencia controlada, propiedad, herramientas aprobadas y tratamiento de datos. Cuando el análisis directo no sea seguro, usar procesos intermediarios controlados. Evidencia: registros, aprobaciones, análisis y excepciones.

25. OT inalámbrica y habilitada por radio

Inventariar Wi-Fi, celular, Bluetooth, radio propietaria e inalámbrica industrial. Documentar cobertura, autenticación, cifrado, gestión de claves, interferencia/resiliencia, detección de dispositivos no autorizados y operación alternativa. Evidencia: inventarios, configuraciones, estudios, rotaciones de claves, monitoreo y decisiones de riesgo.

26. Coordinación e independencia de sistemas de seguridad

Tratar sistemas instrumentados de seguridad y otras funciones de protección conforme a sus requisitos de ingeniería y seguridad funcional. Evaluar dependencias de ciberseguridad, comunicaciones, mantenimiento, fallas comunes e independencia sin afirmar que la ciberseguridad sustituye la ingeniería de seguridad funcional. Evidencia: diagramas, revisiones, reglas y pruebas coordinadas.

27. Pruebas y validación de seguridad

Planificar pruebas sin crear riesgo inaceptable al proceso. Preferir entornos representativos, técnicas pasivas, métodos soportados por proveedor, ventanas controladas y capacidad de reversión. Definir reglas para evaluación de vulnerabilidades, penetración, segmentación, recuperación y configuración. Evidencia: planes, aprobaciones, resultados, hallazgos, remediación y repruebas.

28. Métricas, KRI y arquitectura de evidencia

Medir cobertura de inventario, activos sin soporte, rutas expuestas, acceso remoto, monitoreo, tratamientos vencidos, estado de mitigación, restauración, recurrencia de incidentes y antigüedad de excepciones. Para cada salvaguarda registrar propietario, procedimiento, frecuencia, evidencia, método de prueba, hallazgos, remediación y reevaluación. Las métricas no sustituyen juicio de riesgo.

29. Gobierno de mapeos entre marcos

Mapear conceptos de NIST SP 800-82, referencias ISA/IEC 62443, controles internos y obligaciones solo como ayudas trazables. No afirmar equivalencia uno-a-uno ni herencia de certificación. Registrar fuente/versión, razón del mapeo, brechas, ambigüedad, revisión cuando corresponda e impacto de cambios.

30. Capacitación y competencia

Proporcionar competencia específica para operadores, ingenieros, administradores, respondedores, analistas, seguridad funcional, adquisiciones y proveedores. Cubrir acceso, cambios, medios removibles, soporte remoto, reporte de anomalías, incidentes y consecuencias ciberfísicas. Evidencia: planes por rol, finalización, ejercicios, desempeño y acciones correctivas.

31. Excepciones y aceptación de riesgo

Documentar activo/proceso afectado, salvaguarda, justificación técnica u operativa, consecuencia, controles compensatorios, responsable, vencimiento, objetivo de remediación y reevaluación. Las excepciones de alta consecuencia requieren escrutinio proporcional y no deben perpetuarse por descuido administrativo. Evidencia: registro, revisiones, riesgo residual y cierre.

32. Cambios de fuente, localización, QA de artefactos y liberación

Vigilar cambios de NIST, ISA/IEC 62443, prácticas de avisos CISA, soporte de proveedores y demás fuentes adoptadas. El inglés exacto permanece congelado antes de es-419 y pt-

BR. Exigir paridad trilingüe, generación reproducible de seis binarios DOCX/PDF, QA de renderizado y accesibilidad, procedencia SHA-256, seguridad de workflows, staging de bytes exactos, publicación del predecesor y reconciliación de catálogo/registro.

Límite de liberación controlada

Esta localización no constituye asesoría legal, certificación de producto, certificación de seguridad funcional ni certificación ISA/IEC 62443. Los avisos CISA y de proveedores son insumos operativos temporales. Bajo la regla canónica del repositorio, un candidato sin errores ni asuntos pendientes, con todas las puertas objetivas aplicables en verde y el predecesor publicado, procede bajo autorización permanente salvo que un asunto específico y genuinamente no determinista requiera juicio especializado separado.